LEXIGRID

Active Directory SSO - Entra ID and AD FS

Version 5.54.15 | Reviewed 2026-11-11

Shahryar Jahangir, Aniza Inc.

Procedures, examples, verification and operational limits. Complete commissioning on your deployment before serving customer traffic. Sample values are fictional; original keys and data must be preserved.

Contents

Active Directory SSO: Entra ID and AD FS **3**

Entra ID using OIDC . . . 3

On-premises AD FS using SAML . . . 4

Enable and verify . . . 4

Multi-tenant administration **5**

Roles and scope . . . 5

Provision an organization . . . 5

Tenant user creation . . . 5

Entra/AD FS binding . . . 5

Security checks . . . 5

Operational recovery . . . 6

Active Directory SSO: Entra ID and AD FS

LexiGrid can expose Microsoft Entra ID (OIDC) and on-premises AD FS (SAML) sign-in together. Each deployment has one configured OIDC issuer and one configured SAML IdP. Users select their LexiGrid organization before choosing a provider. Only pre-provisioned, active accounts explicitly bound to the provider identity can authenticate. Directory groups and token roles do not assign LexiGrid permissions automatically.

Qualify sign-in, sign-out, asserted MFA, denied identities and recovery against your configured directory before enabling customer traffic. Preserve existing encryption keys and administrative recovery credentials.

Entra ID using OIDC

Register a Web application with an exact HTTPS redirect URI:

```
https://YOUR_LEXIGRID_HOST/api/auth/oidc/callback
```

Configure these variables in the existing native environment file or Compose environment, using your approved secret storage for the client secret:

```
LEXIGRID_OIDC_ISSUER=https://login.microsoftonline.com/YOUR_DIRECTORY_TENANT_ID/v2.0
LEXIGRID_OIDC_CLIENT_ID=YOUR_APPLICATION_CLIENT_ID
LEXIGRID_OIDC_CLIENT_SECRET=YOUR_CLIENT_SECRET
LEXIGRID_OIDC_REDIRECT_URI=https://YOUR_LEXIGRID_HOST/api/auth/oidc/callback
LEXIGRID_OIDC_LABEL=Microsoft Entra ID
LEXIGRID_REQUIRE_MFA=1
```

The issuer must be the exact issuer returned by tenant-specific discovery. Generic `common` or `organizations` discovery is not supported by the exact-issuer check. The application uses authorization code flow with PKCE. The application requests `openid email profile`; no Microsoft Graph access is required for this flow.

Bind the user's verified issuer and application-specific `sub` from an independently validated ID token to an existing LexiGrid user. Use the schema-owner connection for this audited administrative command:

```
LEXIGRID_ADMIN_CONFIRM=YES python -m app.admin_cli bind-oidc \
  --tenant-id LEXIGRID_TENANT_UUID --email USER_LOCAL_EMAIL \
  --issuer https://login.microsoftonline.com/YOUR_DIRECTORY_TENANT_ID/v2.0 \
  --subject VERIFIED_APPLICATION_SPECIFIC_SUBJECT
```

Do not substitute an email, UPN or Entra object ID for `sub`. The binding command revokes prior application sessions. Authentication selects the local account by LexiGrid tenant plus issuer and subject, without requiring a matching email claim. Microsoft documents email and preferred username as mutable and unsuitable for authorization in its ID token claims reference (https://learn.microsoft.com/en-us/entra/identity-platform/id-token-claims-reference).

When MFA is required, LexiGrid accepts an explicit signed `amr` MFA assertion, a password plus supported second-factor method, or an explicitly configured MFA authentication context. A lone `otp`/hardware method does not satisfy the check. For Entra tokens without a suitable `amr`, configure a Conditional Access authentication context whose policy requires MFA, then set its exact identifier:

```
LEXIGRID_OIDC_MFA_ACRS=c1
```

`c1` is only an example, not a built-in MFA guarantee. The operator must confirm that the configured context policy requires MFA for every permitted user. LexiGrid requests that context in the ID token and verifies the signed `acrs` value; unknown or absent contexts are rejected unless the signed `amr` separately proves MFA. Context configuration is described in Microsoft's Conditional Access authentication context guide (https://learn.microsoft.com/en-us/entra/identity-platform/developer-guide-conditional-access-authentication-context).

On-premises AD FS using SAML

Configure an AD FS relying-party trust with the LexiGrid SP entity ID and HTTPS ACS callback. AD FS must sign both the response and assertion. Supply the IdP signing certificate and an appropriate stable NameID claim. Configure:

```
LEXIGRID_SAML_SP_ENTITY_ID=https://YOUR_LEXIGRID_HOST
LEXIGRID_SAML_ACS_URL=https://YOUR_LEXIGRID_HOST/api/auth/saml/acs
LEXIGRID_SAML_IDP_ENTITY_ID=YOUR_ADFS_ENTITY_ID
LEXIGRID_SAML_IDP_SSO_URL=https://YOUR_ADFS_HOST/adfs/ls/
LEXIGRID_SAML_IDP_CERT=YOUR_IDP_SIGNING_CERTIFICATE_PEM
LEXIGRID_PUBLIC_HOST=YOUR_LEXIGRID_HOST
LEXIGRID_SAML_LABEL=Active Directory Federation Services
LEXIGRID_REQUIRE_MFA=1
LEXIGRID_SAML_MFA_CONTEXTS=http://schemas.microsoft.com/claims/multipleauthn
```

For the single-line native environment format, enter the PEM value without enclosing quotes and replace each certificate newline with literal `\n`. Both actual PEM newlines and escaped newlines are accepted. Do not paste a multiline certificate as several native configuration lines.

The `http://schemas.microsoft.com/claims/multipleauthn` value is an authentication-context identifier; LexiGrid does not fetch it over HTTP. The actual ACS/SSO transport must use HTTPS. Microsoft discusses this MFA context in its AD FS SSO troubleshooting guidance (https://learn.microsoft.com/en-us/troubleshoot/windows-server/active-directory/troubleshoot-ad-fs-sso-issue). Configure and verify that AD FS returns the approved value as the signed assertion's AuthnContextClassRef after MFA. An authentication-method attribute alone is not accepted by this adapter's context check. Missing context support must not be worked around by allowing a password-only context or disabling MFA.

Bind the independently verified stable NameID to an existing account:

```
LEXIGRID_ADMIN_CONFIRM=YES python -m app.admin_cli bind-saml \
  --tenant-id LEXIGRID_TENANT_UUID --email USER_LOCAL_EMAIL \
  --subject VERIFIED_STABLE_NAMEID
```

Both identity bindings can belong to the same local account. Roles, tenant membership and account activation remain managed in LexiGrid. Subject changes and certificate rollover require controlled administrative updates and interoperability verification.

Enable and verify

After configuring the providers, restart the API using the existing deployment procedure. Compose now forwards both providers' variables and the MFA policy. The login page shows each provider only when its required configuration is present; incomplete configuration does not produce an active sign-in button. Configuration presence does not prove IdP connectivity or policy correctness.

Use a nonproduction, provisioned account to verify both providers independently: successful MFA login reaches the workspace, password-only login is rejected when MFA is required, the wrong organization is denied, disabled/unbound users are denied, and the audit trail contains one event for each successful sign-in. Browser callbacks use signed state and scoped secure cookies, return a nonce-protected HTML handoff, store the token in same-origin session storage, and navigate to `/ui`. Tokens are not placed in URL queries or fragments. Direct API starts without `ui=true` retain JSON callback responses.

No installed environment, production IdP or customer database is modified by adding this configuration support. A deployment-specific restore path and access checks remain prerequisites for production activation.

Multi-tenant administration

Roles and scope

A platform administrator may provision a named tenant and initial tenant administrator. A tenant administrator manages supported user operations within its signed-in tenant. A risk contact's owner/watcher/approver/auditor/reviewer label is descriptive and grants no login or API permission.

Tenant names are visible in the unauthenticated organization selector. Their visibility does not grant membership or authorize a tenant switch. Every object/query/import/attachment/report must be checked against the authenticated tenant, with PostgreSQL RLS as an additional enforcement layer.

Provision an organization

1. Sign in as platform administrator and confirm the current tenant/role.

2. Open Administration and enter the new organization name, initial administrator email and a strong initial password through the protected form.

3. Submit once. Creation of the tenant/user is atomic and audited under the actual actor.

4. Verify the tenant in the selector, the initial account role and successful designated test login.

5. Confirm a tenant administrator cannot call the platform provisioning API and cannot view another tenant's ordinary user list.

Duplicate names/accounts produce a conflict rather than a partial organization. Do not reuse a business owner's email as a substitute for a formally authorized administrator.

Tenant user creation

Within Administration, provide normalized email, password and a permitted tenant role. The server uses the caller's tenant rather than accepting arbitrary target tenant IDs. Verify the new account in that tenant's user list, its role, active state and the user-create audit event. Passwords must not appear in responses or audit details.

Use Change access beside a user to set their tenant role or active state. Deactivation blocks sign-in and revokes sessions; reactivation does not restore old tokens. Stale security revisions are rejected. Another administrator must change your account; platform administrator access requires privileged owner administration. The server serializes organization access changes and preserves an active administrator. Owner CLI identity binding and password recovery remain separate privileged operations. User records and historical authorship are retained.

Entra/AD FS binding

Configure federation per the SSO manual. Pre-provision the local account and bind exact issuer/application subject for OIDC or stable NameID for SAML. Both bindings may refer to the same local account. They do not assign a role from directory claims. A signed token containing the same email as another user is not sufficient to authenticate that account.

Security checks

Use two synthetic tenants and separate test users. Verify foreign-tenant GET/import/download denial, role denial and audit attribution. In PostgreSQL, the API must use restricted lexigrid_runtime, not a schema owner. Platform provisioning temporarily scopes new-user creation to the new tenant, then restores the caller context before audit/commit. Ordinary requests do not receive platform-wide object access merely because the actor is platform_admin.

Operational recovery

For a stale/conflicting change, refresh the displayed record and verify current state before retrying. Do not bulk-reset users or tenants to repair an import or SSO issue. Preserve original keys so existing MFA/evidence remain readable.
Cross-tenant reporting is separately scoped feature work and is not provided by the standard tenant report.